DOCUFY

Product Requirements Document

Cross-Border Blockchain Document Verification Platform

Enterprise-grade document authenticity, provenance, tamper detection, and instant international verification

Document	Docufy PRD v1.0
Product Type	B2B / B2G cross-border trade integrity platform
Primary Users	Exporters, importers, customs, logistics providers, certifying authorities
Core Trust Model	Cryptographic evidence + permissioned ledger + optional public blockchain anchoring
Primary Documents	Bills of Lading, Certificates of Origin, Phytosanitary Certificates, invoices, packing lists, permits and related trade records
Status	Definitive product blueprint / implementation baseline

Important: Docufy is a technology and product blueprint, not legal advice. Country-specific customs, data-protection, electronic-transactions, records-retention, evidentiary, sanctions, export-control and sectoral requirements must be validated with qualified local counsel and the relevant competent authorities before production deployment.

Document Map

Section	Topic
1	Executive Summary & Problem Statement
2	Target Audience & Personas
3	Product Vision, Principles & Scope
4	Core Product Features & Functional Requirements
5	Technical Architecture & Blockchain Strategy
6	Data Model, Cryptography & Trust Model
7	UX & End-to-End Workflows
8	Regulatory Compliance, Privacy & Security
9	Non-Functional Requirements
10	Success Metrics & KPI Framework
11	Implementation Roadmap & Release Strategy
12	Risks, Dependencies & Open Decisions
13	Acceptance Criteria & Definition of Done

1. Executive Summary & Problem Statement

Product vision. Docufy is a cross-border trade document integrity platform that enables authorized organizations to issue, cryptographically fingerprint, anchor, track and verify critical trade documents. Its objective is not to replace customs systems or legal documentary regimes; it is to create a shared, machine-verifiable evidence layer that makes unauthorized document alteration materially harder to execute and materially easier to detect.

Context. International trade depends on documentary assertions: origin, quantity, ownership, shipment, inspection, sanitary status, transport, value and regulatory eligibility. Illicit trade networks can exploit weaknesses in paper records, PDFs, email attachments, disconnected databases, forged stamps/signatures, altered dates or quantities, and inconsistent versions presented to different parties. The operational problem is amplified by multi-party handoffs across jurisdictions, time zones and technology stacks.

Core problem. A verifier frequently receives a document without an independently trustworthy mechanism to establish: (1) who issued it, (2) whether the exact artifact has changed, (3) whether the issuer was authorized at issuance time, (4) whether it has been revoked or superseded, and (5) what authoritative evidence exists around the document's lifecycle.

Docufy proposition. Bind a document's canonical cryptographic digest to a trusted issuer identity and an auditable event record. Store sensitive content off-chain in controlled repositories; store only the minimum evidence necessary on a ledger; expose verification through a QR code, verification token, API, or reference ID. A verifier receives a deterministic result with evidence rather than relying on visual inspection.

Strategic outcome. Establish a network effect: the more exporters, certifying bodies, carriers, customs authorities, banks and importers participate, the more trade documents can be verified at the point of decision. The platform becomes a trust infrastructure rather than another document repository.

Problem statement

- **Forgery:** counterfeit documents, forged signatures/seals, cloned templates and fabricated issuer identities can be difficult to distinguish from legitimate artifacts.
- **Tampering:** small changes to consignee, commodity, quantity, origin, dates, container numbers or certificates may materially alter compliance or financial outcomes.
- **Version ambiguity:** multiple PDF scans and email attachments can circulate without a clear authoritative version.
- **Verification latency:** manual calls, emails and portal lookups create delays and are difficult to scale across jurisdictions.
- **Fragmented evidence:** each participant may maintain a separate database, preventing a consistent chain of provenance.
- **Insider and credential risk:** compromised issuer accounts can be used to produce fraudulent documents unless issuance authority, signing keys and approvals are strongly controlled.
- **Privacy exposure:** putting full trade documents or personal/commercial data on an immutable public chain can create irreversible privacy and confidentiality failures.

Product thesis: the immutable layer should prove integrity, provenance and state; it should not become the repository for sensitive trade documents. Docufy therefore uses a privacy-by-design separation between content, metadata, cryptographic evidence and public verification.

2. Target Audience & Personas

Persona	Primary Goal	Key Jobs-to-be-Done	Critical Needs
Exporter / Manufacturer	Issue trusted documents quickly	Create document; obtain authorized signature; share with buyer/carrier/customs	Low friction, templates, signing controls, status tracking
Importer / Buyer	Confirm legitimacy before accepting goods	Verify origin/shipment/certificates; retain evidence	Instant verification, API, clear status, audit export

Persona	Primary Goal	Key Jobs-to-be-Done	Critical Needs
Customs / Border Authority	Detect fraudulent or inconsistent declarations	Verify documents; inspect issuer authority; investigate exceptions	High assurance, search, risk signals, evidence package, case workflow
Certifying Authority	Issue authoritative certificates	Approve, sign, revoke, renew and audit certificates	Delegated authority, key custody, revocation, batch issuance
Logistics Provider / Carrier	Validate shipment documents	Check B/L and supporting documents; link shipment references	Mobile/QR verification, API, event timestamps
Trade Finance / Insurer	Reduce documentary and counterparty risk	Validate documents before financing/coverage	Machine-verifiable evidence, issuer reputation, audit trail
Docufy Admin / Network Operator	Govern trust network	Manage organizations, roles, schemas, policies and incidents	Strong RBAC, segregation of duties, observability, governance controls

Personas and trust boundaries

Docufy must distinguish **identity**, **organizational authority**, **document authorship**, **document possession**, and **verification authority**. A person being authenticated does not by itself prove that their organization was authorized to issue a specific document. The authorization policy must be independently enforceable and auditable.

3. Product Vision, Principles & Scope

Vision: **Make the authenticity of cross-border trade documents machine-verifiable in seconds, across organizational and jurisdictional boundaries.**

Design principles

- **Evidence, not blockchain theater:** blockchain is used where immutability and shared state create measurable value.
- **Privacy by design:** document content remains off-chain unless a specific legal and architectural requirement dictates otherwise.
- **Issuer-centric trust:** verification includes who issued the record and whether the issuer was authorized.
- **Cryptographic determinism:** the same canonical artifact must produce the same digest.
- **Explicit status:** VALID, REVOKED, SUPERSEDED, EXPIRED, INVALID or UNKNOWN must never be ambiguous.
- **Interoperability first:** API, QR, standard identifiers and structured data support integration with customs, ERP, TMS, port and trade platforms.
- **Fail closed:** inability to validate a required trust condition should not silently produce a positive verification result.
- **Human-readable evidence:** every machine decision must be explainable to an investigator.

Scope

In Scope (MVP)	Later / Optional	Out of Scope
Organization onboarding and RBAC	AI-assisted anomaly scoring	Acting as a customs authority
Document upload, canonicalization and SHA-256 hashing	Cross-document graph analytics	Replacing national customs clearance systems
Issuer approval and cryptographic signing	Zero-knowledge selective disclosure	Issuing legal certificates without an authorized issuer

In Scope (MVP)	Later / Optional	Out of Scope
Ledger anchoring and immutable lifecycle events	IoT/IoT container telemetry	Holding customer fiat or crypto funds
QR/public or authorized verification	Native eBL/eCMR/e-invoice ecosystems	Determining legal origin autonomously
Revocation/supersession	Advanced sanctions/dual-use screening	Guaranteeing physical authenticity of goods
Audit logs and evidence packages	Federated multi-network bridge	Permanent storage of raw PII on a public chain

4. Core Product Features & Functional Requirements

4.1 User Authentication & RBAC

- **Enterprise identity:** support OIDC/SAML SSO for organizations; local credentials only where required for smaller entities.
- **MFA:** phishing-resistant methods such as FIDO2/WebAuthn should be preferred for privileged users.
- **Organization model:** Organization → legal entity → departments → users → roles → permissions.
- **RBAC:** Issuer, Approver, Compliance Officer, Verifier, Auditor, Organization Admin, Network Admin; custom roles may be configured.
- **ABAC overlay:** enforce contextual policies such as document type, jurisdiction, issuer accreditation, shipment, counterparty or risk classification.
- **Segregation of duties:** configurable maker-checker for high-value/high-risk issuance and revocation.
- **Session controls:** device/session management, step-up authentication, idle timeout and privileged action re-authentication.
- **Key lifecycle:** organization signing keys should be managed using HSM-backed custody or an equivalent enterprise key management architecture.

4.2 Document Issuance & Cryptographic Hashing

ID	Requirement	Priority	Acceptance Principle
DOC-001	Accept PDF and selected structured document formats; enforce MIME/type validation and malware scanning.	P0	Unsafe or unsupported files are rejected before processing.
DOC-002	Generate SHA-256 digest over a canonical byte representation; preserve original artifact metadata separately.	P0	Identical canonical input yields identical digest.
DOC-003	Bind digest to issuer organization, document ID, type, schema version, issuance timestamp and status.	P0	Verification can reconstruct the evidence binding.
DOC-004	Cryptographically sign issuance event using organization-controlled key.	P0	Signature verifies against registered issuer key.
DOC-005	Anchor evidence to ledger and record transaction/block reference.	P0	Ledger evidence is independently queryable.
DOC-006	Support revocation and supersession without deleting historical evidence.	P0	Old record remains auditable but status changes deterministically.

ID	Requirement	Priority	Acceptance Principle
DOC-007	Generate QR/deep link containing non-sensitive verification reference.	P0	QR resolves to verification result without exposing document content.
DOC-008	Support schema/version evolution.	P1	Historical records remain verifiable after schema updates.

4.3 Cross-Border Verification Portal

- **Verification modes:** QR scan, verification token/reference ID, transaction/hash lookup, API, and authenticated enterprise search.
- **Public mode:** return minimum evidence: document type, issuer identity, issuance time, digest match, status, ledger anchor and verification time.
- **Authorized mode:** permit additional metadata based on role and bilateral/organizational access policy.
- **Result semantics:** VALID means the artifact and issuer binding are verified and current; INVALID means digest/signature/evidence mismatch; REVOKED means issuer withdrew validity; SUPERSEDED means a newer authoritative record exists; EXPIRED means validity window ended; UNKNOWN means insufficient evidence.
- **Evidence package:** downloadable verification receipt containing verification ID, timestamp, hash, ledger reference, issuer identity, status and policy version.
- **Offline/low-connectivity mode:** where operationally necessary, allow a signed verification response to be cached for later reconciliation, clearly marked as not-live.

4.4 Tamper Detection & Audit Trail

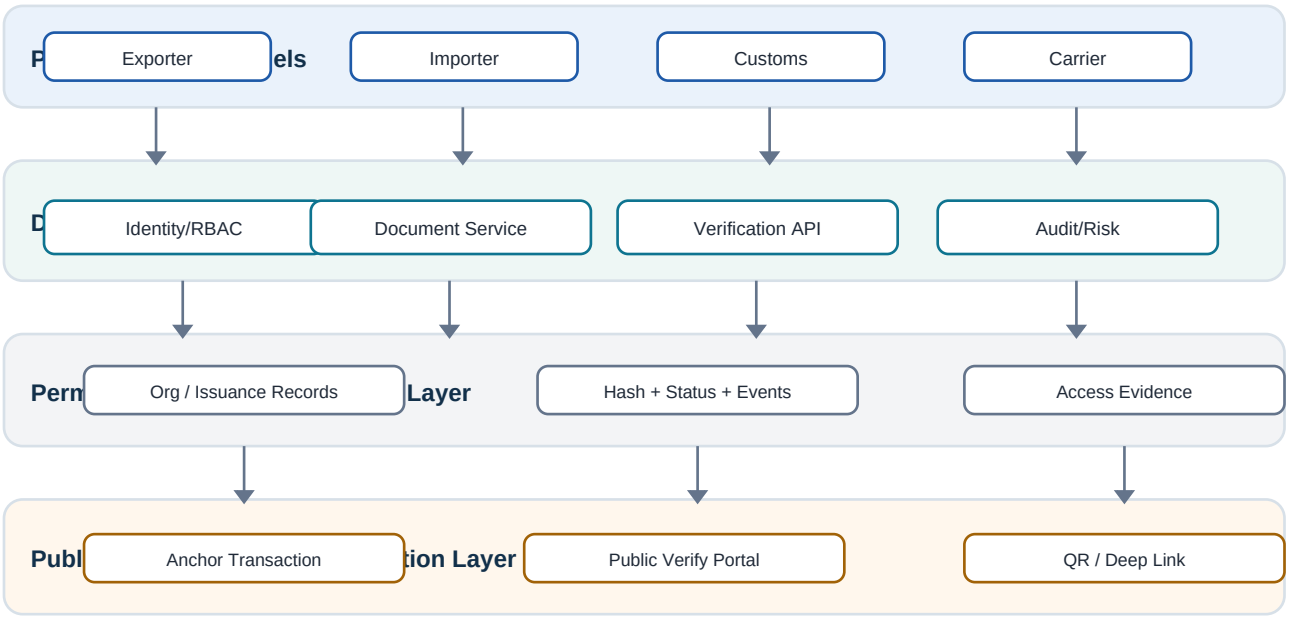
- Append-only audit events for create, approve, sign, issue, view, verify, download, share, revoke, supersede, admin changes and key events.
- Each sensitive event receives a timestamp, actor identity, organization, role, device/session context where legally permissible, action, target object, result and correlation ID.
- Tamper detection compares the presented artifact's digest with the authoritative digest and validates the issuer signature and ledger state.
- Audit records should themselves be protected through hash chaining, immutable storage and/or ledger anchoring.
- Investigation view should reconstruct document lifecycle chronologically and identify policy exceptions.

4.5 Organization & Trust Registry

- Organization legal identity, registration identifiers, jurisdictions, accreditation/certification metadata and status.
- Issuer authority registry: which organization may issue which document types for which jurisdictions and validity periods.
- Public key registry and certificate/key status.
- Delegation records for subsidiaries, agents, certifying officers and delegated issuers.
- Governance workflow for onboarding, suspension, revocation and emergency key rotation.

5. Technical Architecture & Blockchain Strategy

Recommended architecture: **hybrid trust architecture**. Use a permissioned ledger for business-private state and operational governance, while optionally anchoring periodic Merkle roots or selected document proofs to a public EVM network for independently observable timestamping and anti-censorship assurance. Do not put raw documents or sensitive PII on a public blockchain.



5.1 Architectural layers

Layer	Responsibilities	Recommended Technologies
Experience	Web app, responsive verifier portal, QR workflow, admin console	React/Next.js, TypeScript, design system
API & Identity	API gateway, OIDC/SAML, RBAC/ABAC, rate limiting	Node.js/NestJS or Java/Spring Boot; Keycloak/enterprise IdP; OAuth 2.1/OIDC
Document Services	Upload, malware scanning, canonicalization, hashing, OCR/structured extraction where applicable	Object storage, ClamAV/equivalent, containerized workers
Trust Services	Issuer registry, key registry, signing, policy evaluation, revocation	HSM/KMS, PKI, policy engine
Ledger	Shared document evidence, lifecycle state, issuer and authority records	Hyperledger Fabric for consortium/private deployment; alternatives include Besu/Quorum-style EVM permissioned networks
Public Anchor	Independent proof/timestamp layer	Ethereum L2 / Polygon-class EVM L2; anchor Merkle roots rather than full records
Integration	ERP/TMS/customs/port/bank APIs, webhooks, standards mapping	REST/JSON, event streaming, adapters, schema registry
Observability	Logs, metrics, traces, security events, SIEM integration	OpenTelemetry, Prometheus/Grafana, enterprise SIEM

5.2 Blockchain decision matrix

Criterion	Hyperledger Fabric	Ethereum / EVM L2	Recommended Use
Privacy	Strong via channels/private data collections	Public by default; encryption does not solve metadata exposure	Fabric for private consortium state

Criterion	Hyperledger Fabric	Ethereum / EVM L2	Recommended Use
Public verifiability	Requires additional public proof layer	Native public verification	EVM L2 for optional anchoring
Enterprise governance	Strong consortium governance model	Depends on chain/operator	Fabric for core consortium
Smart-contract model	Chaincode; policy-driven	Solidity/EVM ecosystem	Use where interoperability/value warrants
Operational cost	Infrastructure/network governance cost	Transaction fees; L2 generally lower	Anchor batched proofs, not every raw document
Identity	Certificate-based identities integrate naturally	Wallet/key model; enterprise custody required	Fabric CA/enterprise PKI + controlled EVM anchor key
Best fit	Private trade network and authoritative state	Independent public evidence/timestamp	Hybrid

Architecture recommendation: For an initial institutional network, deploy Hyperledger Fabric as the authoritative consortium ledger. Periodically construct a Merkle tree of document-event hashes and publish only the Merkle root plus minimal anchoring metadata to an EVM Layer 2. This provides private operational state plus independently verifiable public evidence without exposing trade content.

5.3 Smart-contract / chaincode responsibilities

- Document registration: document ID, digest, issuer ID, document type, schema version, issuance state and timestamps.
- Issuer authorization: permitted document type, jurisdiction, validity window and organization status.
- Lifecycle state machine: DRAFT → APPROVED → ISSUED → REVOKED / SUPERSEDED / EXPIRED.
- Public anchor registry: Merkle root, anchor transaction ID, anchoring timestamp and proof version.
- Do not encode arbitrary PII, raw documents, free-form trade descriptions or sensitive commercial terms into immutable ledger state.

6. Data Model, Cryptography & Trust Model

6.1 Logical entities

Entity	Key Fields
Organization	org_id, legal_name, jurisdiction, registration_id, status, accreditation, created_at
User	user_id, org_id, role_ids, identity_provider_subject, status, MFA state
Issuer Credential	credential_id, org_id, public_key/certificate, algorithm, valid_from/to, status
Document	document_id, doc_type, schema_version, issuer_id, digest, storage_pointer, issued_at, status
Document Event	event_id, document_id, actor, action, timestamp, event_hash, signature, correlation_id
Verification	verification_id, document/reference, verifier context, result, policy_version, timestamp
Authority Policy	policy_id, jurisdiction, doc_type, authorized_issuer, effective period, policy version
Public Anchor	anchor_id, merkle_root, chain_id, tx_hash, block/reference, anchored_at

6.2 Cryptographic controls

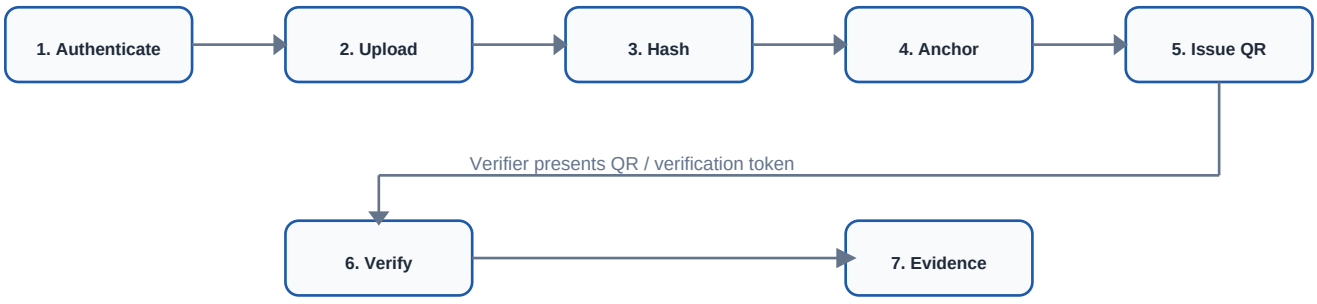
Control	Baseline
Document digest	SHA-256; consider SHA-512/256 where ecosystem policy requires it.
Digital signatures	Ed25519 or ECDSA P-256 for application-level signatures; use algorithm agility and documented rotation policy.
Transport	TLS 1.3 preferred; TLS 1.2 only where required for interoperability.
At-rest encryption	AES-256 or cloud KMS envelope encryption; keys separated from ciphertext.
Key custody	HSM or managed KMS for issuer and platform signing keys; strict export restrictions.
Secrets	Dedicated secrets manager; no credentials in source code or container images.
Password storage	Argon2id or equivalent modern password hashing where local passwords are unavoidable.
Integrity of audit log	Hash chaining plus immutable/WORM retention and/or ledger anchoring.
QR security	Opaque random verification token or signed reference; never embed raw PII or confidential content.

6.3 Content-versus-evidence separation

Recommended pattern: **Object Storage / DMS** stores encrypted document bytes; **Docufy database** stores operational metadata; **permissioned ledger** stores the authoritative cryptographic evidence and lifecycle events; **public chain** stores only batched proof anchors. This minimizes privacy risk and permits lawful deletion or retention management for off-chain content while preserving proof that a particular digest was registered at a particular time.

Canonicalization is a critical technical dependency. A PDF that is re-rendered, re-signed or metadata-modified may produce a different byte hash despite visually identical content. Docufy must define exactly what constitutes the authoritative artifact and, where required, support document-level and structured-field-level hashes.

7. User Experience (UX) & End-to-End Workflows



7.1 Issuer journey

- **1. Sign in:** user authenticates via enterprise SSO/MFA.
- **2. Select document type:** choose B/L, Certificate of Origin, Phytosanitary Certificate or configured type.
- **3. Validate:** Docufy checks file type, schema/template, malware, mandatory fields and issuer authority.
- **4. Upload:** document is encrypted and stored off-chain.

- **5. Fingerprint:** canonical artifact digest is generated; optional structured-field hashes are generated.
- **6. Approve:** maker-checker approval occurs where required.
- **7. Sign:** authorized issuer key signs the issuance evidence.
- **8. Anchor:** evidence is committed to the permissioned ledger; public anchoring occurs according to policy.
- **9. Issue:** system creates verification reference and QR code.
- **10. Share:** exporter shares the document plus QR/reference through the approved channel.

7.2 Verifier journey

- Scan QR or enter verification reference.
- Docufy resolves the record and validates the current ledger state.
- If the original document is supplied, calculate its digest and compare with the authoritative digest.
- Validate issuer identity, issuer authorization, signature, validity window and revocation/supersession status.
- Validate public anchor proof where applicable.
- Display a clear result with evidence and verification timestamp.
- If failed, present the exact reason category without exposing sensitive internal security details.

7.3 Exception workflows

Scenario	Expected Behavior
Document altered	Result INVALID; show digest mismatch; preserve verification event.
Issuer key compromised	Suspend credential, freeze issuance, revoke affected credentials according to incident policy, initiate investigation.
Document revoked	Result REVOKED; show revocation timestamp and authorized revoker where policy permits.
Document superseded	Result SUPERSEDED; link to successor reference if disclosure policy permits.
Ledger temporarily unavailable	Do not silently claim live validity; show service state and, if enabled, signed cached verification with age indicator.
QR copied to another document	QR resolves to authoritative record; supplied artifact hash will not match, producing INVALID.
Issuer not authorized	Reject issuance or mark verification invalid based on the authoritative issuer policy.

8. Regulatory Compliance, Privacy & Security

8.1 Regulatory and standards alignment

Domain	Design Requirement
International trade / customs	Map document metadata to relevant customs/trade data requirements; maintain jurisdiction-specific profiles and legal-owner responsibility for substantive declarations.
UN/CEFACT	Align structured trade-document concepts and data exchange patterns where applicable; use standard identifiers and controlled vocabularies rather than proprietary semantics.
WCO	Design mappings to the WCO Data Model where customs-facing data exchange is required.

Domain	Design Requirement
Electronic trade documents	Assess applicable electronic transferable records/e-document laws, including jurisdictional adoption of frameworks such as UNCITRAL model laws, before asserting legal equivalence to originals.
GDPR / privacy	Data minimization, purpose limitation, access controls, lawful basis, retention rules, data-subject rights where applicable, DPIA for high-risk processing, processor/controller allocation and cross-border transfer controls.
Records/evidence	Define retention, evidentiary export, time synchronization, audit integrity and legal hold processes.
Sanctions / export controls	Integrate with appropriate compliance systems where Docufy is used for screening; do not assume blockchain verification is sanctions clearance.
Cybersecurity	Use a risk-based program aligned to recognized frameworks such as ISO/IEC 27001, NIST CSF and secure SDLC controls.

Privacy rule: never treat immutability as a reason to place personal data on-chain. Use opaque identifiers, salted/peppered references where appropriate, encrypted off-chain storage, selective disclosure, strict retention, and a documented process for correcting/deleting off-chain data. Public-chain anchoring must be designed so the anchor cannot itself become a personal-data leak.

8.2 Threat model

Threat	Control Strategy
Credential theft	Phishing-resistant MFA, conditional access, device/session controls, step-up authentication.
Issuer key compromise	HSM/KMS, key rotation, certificate status, dual control, emergency revocation.
Malicious insider	SoD, least privilege, approval workflows, immutable audit, UEBA/SIEM alerts.
Document malware	Sandboxing/AV, content disarm where appropriate, file-type validation, isolated processing.
API abuse / enumeration	Opaque IDs, rate limits, WAF, auth scopes, anomaly detection, anti-enumeration responses.
Ledger manipulation	Consortium governance, endorsement policies, node separation, independent monitoring and public anchoring.
Supply-chain compromise	SBOM, signed builds, dependency scanning, SLSA-aligned build controls, secrets scanning.
DDoS / availability attack	CDN/WAF, autoscaling, rate limiting, multi-zone deployment, queue-based processing.
Privacy leakage	Data classification, minimization, encryption, access logging, tokenization and privacy review of ledger fields.

8.3 Security baseline

- Zero-trust network segmentation between public web, application services, document-processing workers, databases, ledger nodes and administrative plane.
- Separate production signing keys from application runtime credentials.
- Mandatory security review for smart contracts/chaincode, including threat modeling and independent audit before mainnet/production deployment.
- Continuous dependency, container, infrastructure-as-code and secret scanning.
- Centralized security logging with immutable retention and SIEM integration.

- Incident response playbooks for issuer compromise, key compromise, fraudulent issuance, data leakage, chain outage and verifier abuse.
- Regular penetration testing, red-team exercises and disaster-recovery testing.

9. Non-Functional Requirements

Category	MVP Target	Production Target
Verification latency	p95 ≤ 2.5 sec excluding client/network	p95 ≤ 1.5 sec for normal verification
Availability	99.5%	≥99.95% for verification API; issuance target ≥99.9%
Integrity	100% of issued records have digest + signature	100%; continuous reconciliation
Audit completeness	All P0 lifecycle actions logged	All security/business events with immutable evidence
Scalability	1M document records; 100 verifications/sec burst	10M+ records; horizontally scalable verification
RPO/RTO	RPO ≤ 15 min; RTO ≤ 4 hr	RPO ≤ 5 min; RTO ≤ 60 min for core services
Accessibility	WCAG 2.2 AA target for web UI	WCAG 2.2 AA; multilingual design
Interoperability	REST API + webhooks	API gateway, versioning, event streaming and standards adapters
Observability	Logs + basic metrics	Full metrics, traces, security analytics, SLOs

10. Success Metrics (KPIs)

KPI	Definition	Initial Target / Direction	Fraud-Reduction Relevance
Verification adoption	Verified eligible documents / total eligible documents	≥70% in pilot cohort	Higher coverage reduces unverifiable transactions
Median verification time	Time from verifier request to result	<10 sec end-to-end user journey	Replaces manual calls/emails
Tamper detection rate	Confirmed altered artifacts detected / altered artifacts presented	≥99% for in-scope document artifacts	Core integrity outcome
False-positive verification rate	Invalid artifacts incorrectly marked valid	Near zero; severity-1 target 0	Critical safety KPI
Fraud loss avoided	Estimated prevented loss attributable to Docufy	Track by cohort and verified incident	Business value
Issuer onboarding time	Approved org from application to production	<1 business day for pre-qualified enterprise	Network expansion
Issuance integrity	Issued records with valid signature/ledger evidence	100%	Trust foundation

KPI	Definition	Initial Target / Direction	Fraud-Reduction Relevance
Revocation propagation	Time for revocation to become visible to verifiers	<60 sec target	Limits continued use of compromised docs
Verification API success rate	Successful responses / valid requests	≥99.9%	Operational trust
Audit reconstruction time	Time to reconstruct a document lifecycle	<5 minutes	Investigation efficiency
Manual verification reduction	Manual verification actions before vs after	≥50% reduction in pilot	Operational efficiency
Security incidents	Material security incidents per period	Zero critical; downward trend	Trust and resilience

North-star metric: *Verified Trade Documents with No Integrity Exceptions* — the percentage of eligible cross-border documents that are independently verified as authentic, authorized and current without manual exception handling.

11. Implementation Roadmap & Release Strategy

Phase	Scope	Exit Criteria
0 — Discovery & Network Design	Select pilot corridor, document types, legal entities, issuer authorities, governance model, data schemas and legal basis.	Signed pilot charter; threat model; legal/compliance assessment; target architecture.
1 — MVP	Identity/RBAC, organization onboarding, document upload, hashing, issuance, permissioned ledger, QR verification, audit trail.	End-to-end issuance and verification works with pilot organizations.
2 — Institutional Pilot	Customs/logistics integrations, issuer authority registry, revocation, APIs, SIEM, operational dashboards.	Measured KPIs meet pilot thresholds; security test passed.
3 — Public Evidence Anchor	Merkle batching to EVM L2, public proof validation, external verifier tooling.	Independent proof verification; privacy review passed.
4 — Scale & Interoperability	Standards adapters, ERP/TMS/port integrations, multilingual support, advanced analytics.	Production SLOs and integration certification achieved.
5 — Multi-Corridor Network	Additional jurisdictions, certifying bodies, cross-network trust federation.	Governance and legal framework supports additional corridors.

Recommended pilot

Start with one bilateral trade corridor and 2–3 high-value document types rather than attempting global coverage. A strong pilot should include at least one exporter, one importer, one logistics provider and one authoritative/certifying participant. Select documents where authenticity verification is operationally valuable and the issuer has a clear legal mandate.

Suggested first document set: Bill of Lading + Certificate of Origin + Phytosanitary Certificate. Add invoice/packing list later once the evidence model and issuer governance are stable.

12. Risks, Dependencies & Open Decisions

Risk / Decision	Impact	Mitigation / Decision Needed
Legal recognition differs by jurisdiction	High	Treat Docufy initially as an integrity/evidence service; obtain local legal validation before asserting electronic-original status.
No authoritative issuer participation	High	Trust registry must be anchored in recognized authorities; otherwise label records as privately issued.
Public blockchain metadata leakage	High	Anchor only Merkle roots/minimal proofs; perform privacy review before publication.
Canonicalization ambiguity	High	Define artifact identity rules and test against document lifecycle operations.
Key compromise	Critical	HSM, dual control, revocation, incident playbook and affected-record investigation.
Consortium governance deadlock	High	Formal governance charter, voting model, node responsibilities and dispute process.
Low adoption / network effect	High	Pilot around one measurable fraud/latency problem and integrate into existing workflows.
Blockchain outage or degraded consensus	Medium	Multi-node architecture, operational fallback, explicit verification states.
False sense of security	High	Product messaging must distinguish document integrity from truth of underlying claims and physical-goods authenticity.

Key open decisions before engineering lock

- Which jurisdictions and bilateral corridor constitute the first production network?
- Which organizations have legal authority to issue each document type?
- Will the authoritative ledger be operated by Docufy, a neutral consortium, or a government/industry body?
- Is the pilot intended to provide evidentiary integrity only, or legally recognized electronic-document functionality?
- Which data fields are required for verification versus confidential to the parties?
- Which EVM L2 and custody model will be approved for public anchoring?
- What retention and deletion periods apply to each document class?
- What is the operational dispute process when an issuer disputes a verification result?

13. Acceptance Criteria & Definition of Done

Area	Definition of Done
Identity	All users authenticate through approved identity controls; privileged roles require MFA; permissions are tested.
Issuance	Authorized issuer can upload, validate, approve, sign and issue a document; digest and ledger evidence are created.
Verification	A verifier can use QR/reference and receive a deterministic status with evidence within the target latency.
Tamper detection	Any change to the verified artifact produces a non-valid integrity result.
Revocation	Authorized revoker can revoke a record; all live verification paths reflect the new status within SLA.

Area	Definition of Done
Audit	Complete lifecycle and security events are captured, queryable and protected from unauthorized alteration.
Privacy	No raw trade document or unnecessary PII is written to public blockchain; data flows have been threat-modeled.
Security	SAST/DAST/dependency/container scans pass; penetration test findings are remediated according to severity.
Resilience	Backup/restore and disaster-recovery tests meet defined RPO/RTO.
Interoperability	Document and verification APIs are versioned, documented and tested with at least one external integration.
Operations	SLOs, dashboards, alerts, runbooks and incident-response procedures are in place.

Final product positioning

Docufy should be positioned as a **trade document integrity and verification infrastructure**, not merely a blockchain document vault. The differentiator is the combination of authoritative issuer identity, cryptographic document fingerprints, lifecycle state, permissioned governance, public proof anchoring and a fast verification experience. The product succeeds when customs officials, businesses and logistics operators can make a high-confidence authenticity decision without relying on visual inspection or fragmented email-based confirmation.

Appendix A — Example verification response


```
{ "verification_id": "VER-2026-000123", "document_reference": "DOC-COO-7F92...", "document_type":
"CERTIFICATE_OF_ORIGIN", "issuer": { "organization_id": "ORG-...", "name": "Authorized Issuer",
"credential_status": "ACTIVE" }, "integrity": { "algorithm": "SHA-256", "presented_document_hash": "…",
"registered_document_hash": "…", "match": true }, "status": "VALID", "issued_at": "2026-10-08T08:00:00Z",
"ledger_reference": "…", "public_anchor": { "network": "EVM_L2", "transaction": "…", "proof_type":
"MERKLE_ROOT" }, "verified_at": "2026-10-08T08:01:22Z", "policy_version": "VERIFY-1.0" }
```


Appendix B — Recommended technology baseline

Domain	Baseline Recommendation
Frontend	React + TypeScript + Next.js or equivalent enterprise web stack
Backend	NestJS/Node.js or Java/Spring Boot; domain-driven service boundaries
Database	PostgreSQL for operational metadata; Redis for ephemeral caching/queues as appropriate
Object storage	S3-compatible encrypted object storage with versioning and retention controls
Permissioned blockchain	Hyperledger Fabric for consortium/private authoritative evidence
Public anchor	Ethereum-compatible Layer 2; batch Merkle roots
Identity	Enterprise IdP via OIDC/SAML; WebAuthn/FIDO2 for privileged access
Keys	Cloud KMS/HSM; enterprise PKI/certificate lifecycle
Observability	OpenTelemetry + Prometheus/Grafana + SIEM
Deployment	Kubernetes or managed container platform with multi-zone HA
CI/CD	Signed builds, SBOM, dependency scanning, IaC scanning, staged deployment gates

End of Product Requirements Document — Docufy v1.0

Prepared as a product and engineering blueprint. Jurisdiction-specific legal, customs, privacy and evidentiary validation remains a mandatory pre-production workstream.